COMPTIA SECURITY+ SY0-701 | DOMAIN 1 · GENERAL SECURITY CONCEPTS (12%)

Security+ 1.2 · Deception & Disruption

Mestre CyberSec · **Lesson 1.2 — Deception & Disruption** (4:30) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Executive Lesson Summary: Isca e engana: honeypot (máquina falso), honeynet (rede de honeypots), honeyfiles (arquivo-isca), DNS sinkhole (redireciona domínio malicioso pra nada), false azure (serviço que finge ser cloud). Detecta e estuda o atacante.

💡 Key Exam Highlights & Critical Concepts

- Honeypot = alvo falso: parece real, é monitorado
- Honeyfile: documento-isca com beacon — dispara alerta ao abrir
- DNS sinkhole = envia C2 pra IP nulo e LOGA quem tentou

🎯 Exam Tips & Typical CompTIA Scenarios

- 'appears vulnerable but is monitored' = honeypot
- 'redirects malicious domain traffic' = sinkhole

🚨 Beyond the Video: Official Exam Concepts, Protocols & Traps (Section 1.2 — Deception & Disruption)

Why is this advanced coverage required for SY0-701?: Video lectures provide foundational concepts, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

• Honeypot (N/A)

A decoy system or service designed to attract attackers, detect unauthorized access, and gather threat intelligence without exposing real assets.

⚠️ ***Exam Trap:*** *Lembre-se: honeypot é uma isca, não um sistema de produção. Se um atacante interage com ele, é quase certo que seja um ataque. Diferencie de honeynet (rede de honeypots) e honeyfile (arquivo isca).*

• Honeynet (N/A)

A network of multiple honeypots designed to simulate a real network, allowing defenders to observe attacker behavior across a larger environment.

⚠️ ***Exam Trap:*** *Honeynet é uma coleção de honeypots. Não confunda com um único honeypot. É mais realista e pode enganar atacantes por mais tempo.*

• Honeyfile (N/A)

A decoy file placed on a system or network to lure attackers; any access or modification triggers an alert, often used to detect insider threats or compromised hosts.

⚠️ ***Exam Trap:*** *Honeyfile é um arquivo, não um sistema. Se um usuário legítimo acessa, pode indicar comprometimento. Foco em detecção, não em prevenção.*

• DNS Sinkhole

A DNS server that returns a non-routable or false IP address for known malicious domains, preventing access and identifying infected hosts that attempt to resolve them.

⚠️ ***Exam Trap:*** *DNS sinkhole redireciona domínios maliciosos para um endereço controlado, bloqueando a comunicação C2 e revelando máquinas infectadas. Não é um firewall.*

• Fake Telemetry (N/A)

A deception technique that provides false system, network, or application data to attackers, misleading them about the environment and delaying their actions.

⚠️ ***Exam Trap:*** *Fake telemetry é sobre fornecer informações falsas, não apenas um honeypot. Pode incluir arquivos, registros, tráfego de rede falsos. Distinga de honeypot (sistema isca).*

• Tarpit (N/A)

A security service that deliberately delays or stalls attacker connections to consume their resources and slow down automated attacks.

⚠️ ***Exam Trap:*** *Tarpit é uma técnica de disrupção, não de detecção. Ele atrasa o atacante, enquanto honeypot o engana. Pode ser usado para combater worms e bots.*

• False Azure (Fake Cloud Service) (N/A)

A deceptive cloud service that mimics a legitimate cloud platform (e.g., Microsoft Azure) to attract attackers, gather intelligence, and divert attention from real cloud assets.

⚠️ ***Exam Trap:*** *False Azure é um exemplo de honeypot em nuvem. Se a prova mencionar 'serviço que finge ser nuvem', pense em honeypot ou fake cloud. Não confunda com fake telemetry.*

• Deception Technology (N/A)

Security controls that use decoys, traps, and false information to mislead attackers, detect intrusions, and gather threat intelligence.

⚠️ ***Exam Trap:*** *Deception technology é o conceito guarda-chuva que inclui honeypot, honeynet, honeyfile, fake telemetry, etc. O objetivo é detectar e estudar o atacante, não apenas bloquear.*

🏛️ Conceptual Deep Dive, Real-World Analogies & GRC Analysis

📌 Honeypot vs. Honeynet vs. Honeyfile

🏠 **Real-World Analogy:** A Honeypot is a fake safe with fake money placed in the living room just to see who tries to steal it. A Honeynet is an entire fake replica bank. A Honeyfile is a decoy file named 'passwords.xlsx' that triggers an immediate silent alarm when opened.

🔍 **Root Cause & Background:** Attackers actively probe networks looking for easy targets; decoys detect lateral movement before genuine production assets are hit.

🛡️ **GRC Auditor Perspective:** Verify strict network isolation to ensure decoy environments cannot be leveraged as pivot points into production.

⚠️ **How CompTIA Tests This:** Trigger: 'decoy server to gather attacker telemetry' -> Honeypot. 'Fake file triggering alert upon access' -> Honeyfile / Honeytokan.

📌 DNS Sinkhole

🏠 **Real-World Analogy:** It is like postal inspectors intercepting mail addressed to a criminal hideout and rerouting it directly to police headquarters.

🔍 **Root Cause & Background:** Compromised endpoints query DNS to reach attacker C2 servers; sinkholing returns an internal safe IP to sever the connection.

🛡️ **GRC Auditor Perspective:** Monitor DNS sinkhole logs to identify infected internal hosts requiring immediate isolation and remediation.

⚠️ **How CompTIA Tests This:** Trigger: 'redirecting malicious domain queries to a controlled internal IP' -> DNS Sinkhole.

⚡ QUICK-REFERENCE EXAM CHEAT SHEET

Typical Exam Scenario / Practical Situation	Technical Concept & Target Answer
Decoy server deployed to attract and record attacker tactics	**Honeypot**
Fake file deployed as bait to alert on unauthorized internal access	**Honeyfile / Honeydoken**
Reroute malicious C2 domain requests to a safe analysis host	**DNS Sinkhole**

✅ Authentic Practice Questions (10 Real Exam Scenarios)

Scenario-based exam questions. Complete explanations and distractor analysis are provided in the answer key below.

QUESTION 1 · EXAM SCENARIO

During a malware outbreak, endpoints infected with a banking trojan attempt to resolve command-and-control (C2) domains. Network engineers configure internal DNS servers to resolve requests for these known malicious domains to a local loopback IP, severing communication and logging infected client IPs. Which technique was used?

A) DNS Sinkhole

B) Split-horizon DNS

C) DNSSEC zone signing

D) Dynamic DNS (DDNS)

QUESTION 2 · EXAM SCENARIO

A system administrator notices an automated scanner conducting aggressive brute-force SSH attacks against Internet-facing bastions. To exhaust the attacker's sockets and slow down the attack, the firewall responds to SYN packets but intentionally delays TCP data transmission byte-by-byte. Which disruption mechanism is this?

A) Tarpit

B) Rate limiting

C) Stateful packet inspection

D) Web Application Firewall (WAF)

QUESTION 3 · EXAM SCENARIO

To confuse external threat actors during reconnaissance and mislead automated vulnerability scanners, a security team configures services to return falsified operating system banners and synthetic open port responses. What deception concept does this illustrate?

A) Fake telemetry

B) Port forwarding

C) Packet sniffing

D) Network Address Translation (NAT)

QUESTION 4 · EXAM SCENARIO

An enterprise deploys a distributed cluster of decoy servers, simulated routers, and fake Active Directory domain controllers across an entire isolated subnet to observe lateral movement. How is this deception environment classified?

A) Honeynet

B) Demilitarized Zone (DMZ)

C) Air-gapped production subnet

D) Bastion subnet

QUESTION 5 · EXAM SCENARIO

A DevOps engineer creates a dummy AWS IAM access key with zero actual permissions and places it in an internal Git repository. If any API call is ever attempted using this key, the SIEM triggers a critical alert indicating a repository breach. What is this decoy credential called?

A) Honeytoken

B) Session cookie

C) Digital certificate

D) JSON Web Token (JWT)

QUESTION 6 · EXAM SCENARIO

According to CompTIA Security+ SY0-701 objectives, what is the primary defensive objective of deploying deception technology (such as honeypots and honeyfiles)?

A) Divert, delay, and gather actionable threat intelligence on attacker methodologies

B) Permanently replace perimeter firewalls and intrusion prevention systems

C) Automatically sanitize infected endpoints without human intervention

D) Guarantee cryptographic non-repudiation for outbound email traffic

QUESTION 7 · EXAM SCENARIO

When deploying a high-interaction honeypot exposed to the public Internet, what is the greatest operational risk that security engineers must isolate and mitigate?

A) The honeypot being compromised and leveraged as a pivot launchpad to attack other systems

B) Excessive CPU consumption caused by legitimate employee access

C) Depletion of internal private IPv4 addressing subnets

D) Incompatibility with modern TLS 1.3 cryptographic ciphers

QUESTION 8 · EXAM SCENARIO

A security architect is designing a honeynet deployment and needs a specialized gateway appliance to monitor, rate-limit, and filter outbound traffic leaving the honeypot network to prevent malicious outbound activity. What is this security device called?

A) Honeywall

B) Forward proxy cache

C) Load balancer

D) Network Address Translator (NAT)

QUESTION 9 · EXAM SCENARIO

A security operations team wants to study attacker tactics, techniques, and procedures (TTPs) targeting their Linux database servers without risking proprietary customer records. They deploy an isolated, decoy database server populated with synthetic data and active network telemetry. Which control was implemented?

A) Honeypot

B) Bastion host

C) Forward proxy

D) Demilitarized Zone (DMZ)

QUESTION 10 · EXAM SCENARIO

An organization suspects an insider threat is attempting to exfiltrate confidential executive payroll spreadsheets. A security engineer places an unencrypted spreadsheet named 'Q4_Executive_Salaries.xlsx' embedded with a hidden web beacon on the file server. What specific deception control does this describe?

A) Honeyfile

B) Honeynet

C) DNS Sinkhole

D) File Integrity Monitoring (FIM)

ANSWER KEY & COMPREHENSIVE DISTRACTOR EXPLANATIONS

Question 1: Option A — DNS Sinkhole

A DNS sinkhole intercepts DNS queries for known malicious domains and returns a false IP (such as a loopback or sinkhole server), preventing C2 communication while identifying compromised hosts.

Question 2: Option A — Tarpit

A tarpit deliberately slows down incoming network connections by accepting connections and sending data back extremely slowly, exhausting the attacker's resources and stalling automated attacks.

Question 3: Option A — Fake telemetry

Fake telemetry feeds synthetic or deceptive metadata (such as misleading OS banners, fake logs, or spoofed open ports) to reconnaissance tools, wasting the attacker's time.

Question 4: Option A — Honeynet

A honeynet is an entire network consisting of multiple honeypots, simulated routers, and decoy services designed to study comprehensive multi-stage attack behavior.

Question 5: Option A — Honeytoken

A honeytoken is a piece of decoy data or credential (such as a fake API key, dummy password, or fake database record) used to detect unauthorized access or data breaches.

Question 6: Option A — Divert, delay, and gather actionable threat intelligence on attacker methodologies

The primary goal of deception technology is to divert attacks away from critical assets, delay attacker progress, and gather actionable intelligence on threat actor TTPs.

Question 7: Option A — The honeypot being compromised and leveraged as a pivot launchpad to attack other systems

High-interaction honeypots run real operating systems. If fully compromised, attackers could attempt to use them as a pivot point to attack other internal networks or third parties.

Question 8: Option A — Honeywall

A honeywall is a specialized firewall/gateway that sits between honeypots and the outside world to capture traffic and ensure honeypots cannot be used to attack third parties.

Question 9: Option A — Honeypot

A honeypot is an isolated decoy system designed to appear vulnerable, lure attackers, and capture their TTPs without risking real production data.

Question 10: Option A — Honeyfile

A honeyfile is a decoy file planted among legitimate files that contains canary triggers or beacons to alert administrators immediately when opened or copied.